SECURED MESSAGING EXCHANGE PROCEDURE

V 1.0

23rd Feb 2021

DEFINITION OF TERMS

CSR – Certificate Signing Request

SHA – Secure Hash Algorithm

IPS – Instant Payment Switch

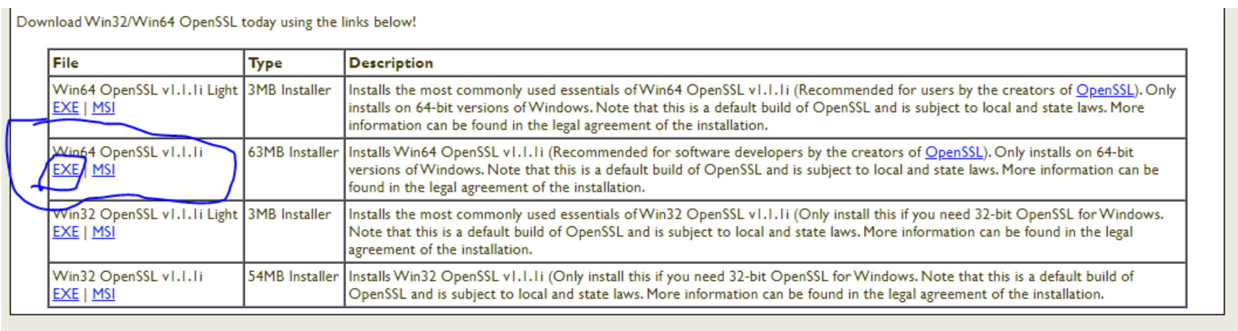
X.509 – A standard defining the format of public key certificates.

1. GENERATING CERTIFICATES FOR IPS

(i) DOWNLOAD AND SETUP OPENSSL

Visit below site to download OpenSSL

https://slproweb.com/products/Win32OpenSSL.html

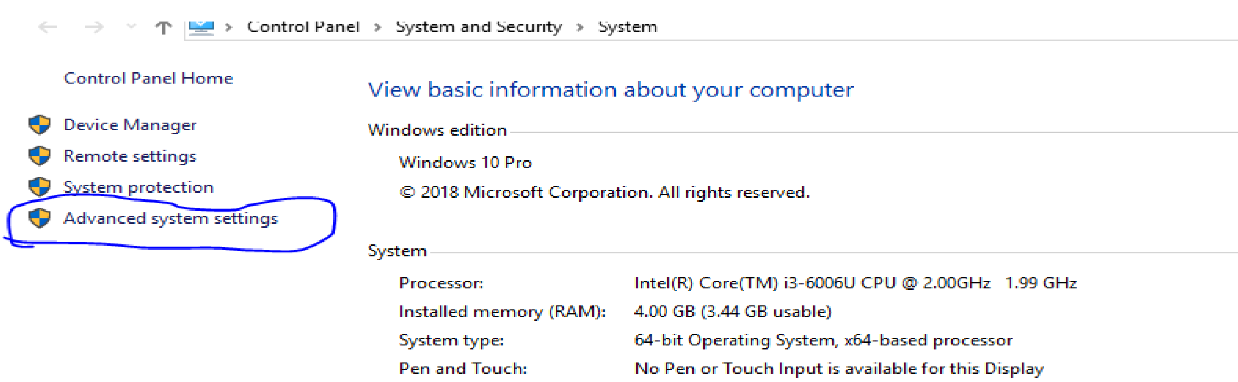


Download Win32/Win64 OpenSSL today using the links below!

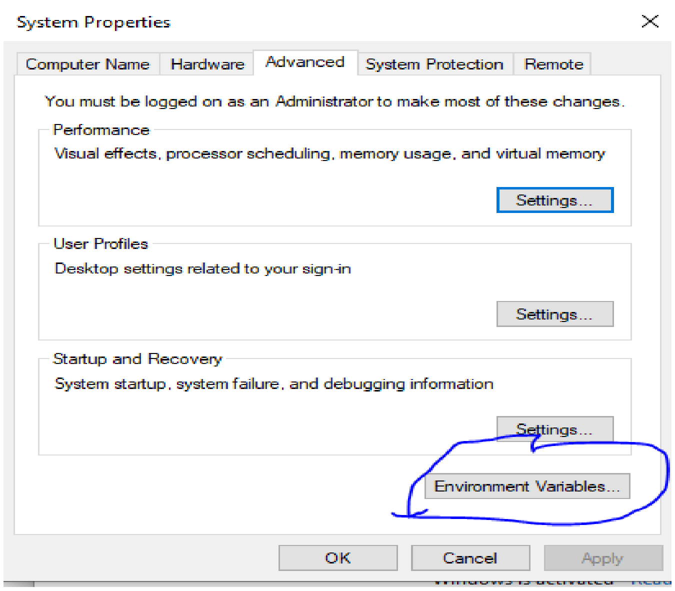
File	Type	Description
Win64 OpenSSL v1.1.1i Light EXE | MSI	3MB Installer	Installs the most commonly used essentials of Win64 OpenSSL v1.1.1i (Recommended for users by the creators of OpenSSL). Only installs on 64-bit versions of Windows. Note that this is a default build of OpenSSL and is subject to local and state laws. More information can be found in the legal agreement of the installation.
Win64 OpenSSL v1.1.1i EXE | MSI	63MB Installer	Installs Win64 OpenSSL v1.1.1i (Recommended for software developers by the creators of OpenSSL). Only installs on 64-bit versions of Windows. Note that this is a default build of OpenSSL and is subject to local and state laws. More information can be found in the legal agreement of the installation.
Win32 OpenSSL v1.1.1i Light EXE | MSI	3MB Installer	Installs the most commonly used essentials of Win32 OpenSSL v1.1.1i (Only install this if you need 32-bit OpenSSL for Windows. Note that this is a default build of OpenSSL and is subject to local and state laws. More information can be found in the legal agreement of the installation.
Win32 OpenSSL v1.1.1i EXE | MSI	54MB Installer	Installs Win32 OpenSSL v1.1.1i (Only install this if you need 32-bit OpenSSL for Windows. Note that this is a default build of OpenSSL and is subject to local and state laws. More information can be found in the legal agreement of the installation.

Install following the default options

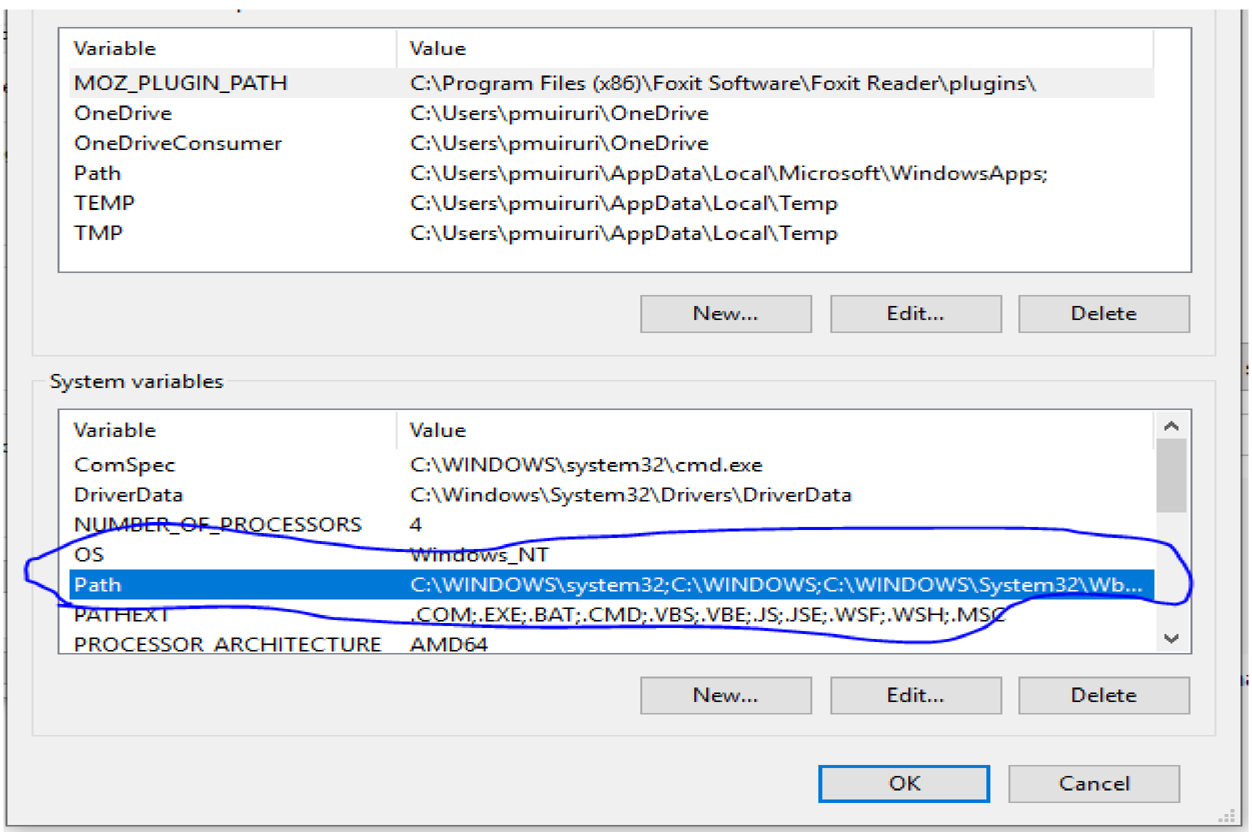
Go to window properties, Advanced Settings



Click on **Environmental Variables**

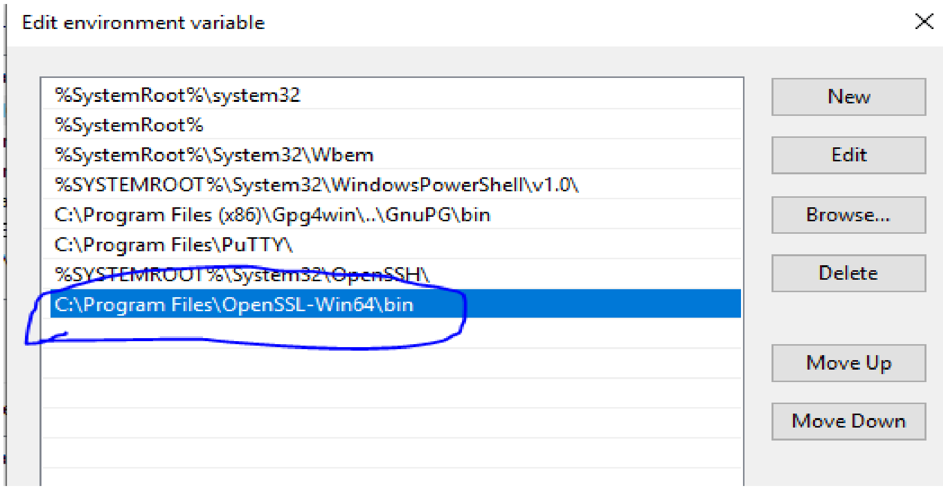


Double-click on “PATH”



If you don’t have this path listed, click on NEW, add it and save

C:\Program Files\OpenSSL-Win64\bin



Now open CMD, type “openssl” under the folder you want to generate the certificates from.

```
C:\Users\pmuiruri\Documents\Certificates and keys>
C:\Users\pmuiruri\Documents\Certificates and keys>
C:\Users\pmuiruri\Documents\Certificates and keys>openssl
OpenSSL>
OpenSSL>
```

You can now proceed to generate the certificates.

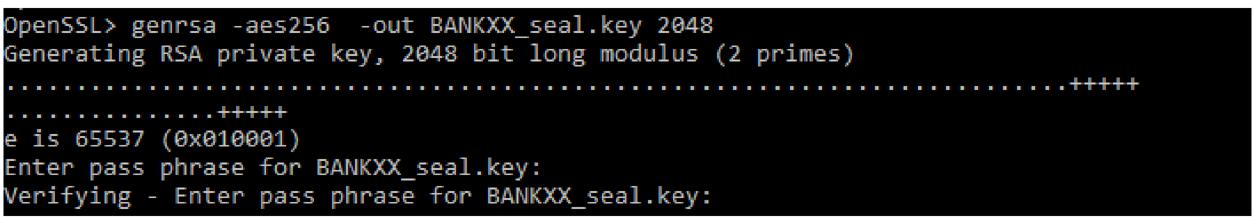
(ii) GENERATE PRIVATE KEY AND CSR

To connect to the new IPS, you will require two certificates: seal and client certificates. To achieve this, you will be required to generate two CSRs (one for seal and the other for client).

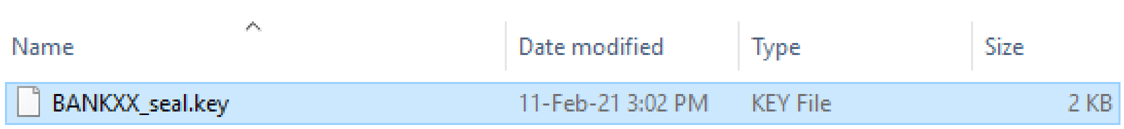
Below is the process for generating a private key and thereafter the CSR:

a. Generating the private key. You need to create the private key and CSRs in the format: **BANK + Bank Code + _ + (seal | client)**

   Command: **openssl genrsa -aes256 -out BANKXX_seal.key 2048.** Where XX is the bank-code, e.g. for bank of 63, we'll have BANK63_seal.key.



b. Confirm we have file in your folder with name BANKXX_seal.key. This is your private key", and it should be stored in a safe place probably a keystore protected with a password.



c. The next step involves creating a CSR with sha256 signature algorithm.

Command: **openssl req -key BANKXX_seal.key -new -sha256 -out BANKXX_seal.csr**

Fill in the details as outlined in the table below:

Abbr		Description	Example

`CN`	Common Name	This is the name to uniquely identify the participant	e.g. MyCompany
`O`	Organization Name	Usually the legal name of a company or entity and should include any suffixes such as Ltd., Inc., or Corp.	MyCompany Inc.
`OU`	Organizational Unit	Internal organization department/division name	IT
`L`	Locality	Town, city, village, etc. name	Nairobi
`ST`	State	Province, region, county or state. This should not be abbreviated	Nairobi
`C`	Country	The two-letter ISO code for the country where your organization is located	KE
`EMAIL`	Email Address	The organization contact, usually of the certificate administrator or IT department	

At this point, you should have a CSR created with name BANKXX_seal.csr

Name	Date modified	Type	Size
BANKXX_seal.csr	11-Feb-21 3:24 PM	CSR File	1 KB
BANKXX_seal.key	11-Feb-21 3:02 PM	KEY File	2 KB

d. You can verify the CSR with the command: **req –text –in BANKXX_seal.csr -noout –verify**. With this, you can verify if the details you entered are correct. If not, repeat the procedure above to re-generate the CSR.

```
OpenSSL> req -text -in BANKXX_seal.csr   -noout -verify
verify OK
Certificate Request:
    Data:
        Version: 1 (0x0)
        Subject: C = KE, ST = NAIROBI, L = NAIROBI, O = Internet Widgits Pty Ltd
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                RSA Public-Key: (2048 bit)
                Modulus:
                    00:c2:4c:f2:56:11:f4:cd:e6:45:73:6b:27:d5:e8:
                    24:6c:01:03:01:85:2d:4d:f3:7f:99:1b:54:f5:0f:
                    b0:d9:06:73:b3:53:99:0a:18:13:f7:24:d4:47:b1:
                    03:92:6f:62:6e:79:b9:58:dc:37:78:a3:de:63:8b:
                    37:da:43:80:11:6b:2e:db:68:02:52:77:a8:bb:37:
                    7a:6a:99:35:28:73:a1:92:97:88:91:53:a6:f0:0b:
                    f1:3a:fb:8a:4e:a8:e7:0c:ff:78:e7:12:f1:7c:6f:
                    77:46:67:1e:f9:2c:67:08:6c:36:20:ae:ac:53:45:
                    63:7d:44:94:60:44:13:03:94:62:f8:af:41:7e:02:
                    4a:b5:b7:ba:38:c1:95:ed:62:23:de:ef:7c:30:57:
                    5f:62:43:6a:34:bc:65:3c:84:e7:a5:b4:04:92:8a:
                    38:50:ec:4b:64:aa:48:a5:ed:84:5e:1f:f9:3e:16:
                    f1:f0:c0:4b:2a:04:dd:f4:40:5d:50:a1:18:e5:76:
                    3b:65:82:8d:98:d7:be:26:36:b0:0c:dd:c9:49:00:
                    0e:e0:a7:31:63:2d:ec:c0:57:a9:b2:a8:f8:eb:51:
                    9b:80:b8:f0:bf:3f:a4:d0:61:0f:fc:50:5d:e5:ee:
                    24:f1:7b:a0:47:db:d3:ad:2b:3d:a1:ed:2e:5e:50:
                    6e:cb
                Exponent: 65537 (0x10001)
        Attributes:
            a0:00
    Signature Algorithm: sha256WithRSAEncryption
         1b:d9:d2:e3:9e:88:49:8d:e9:22:44:68:1b:02:05:b4:2b:68:
         7b:a9:12:13:7c:3f:23:b1:1b:bf:da:7e:c9:19:4e:78:80:9c:
```

NB: While trying to verify the CSR, and you encounter an error like the one shown below, exit openssl, launch it again, then retry the process.

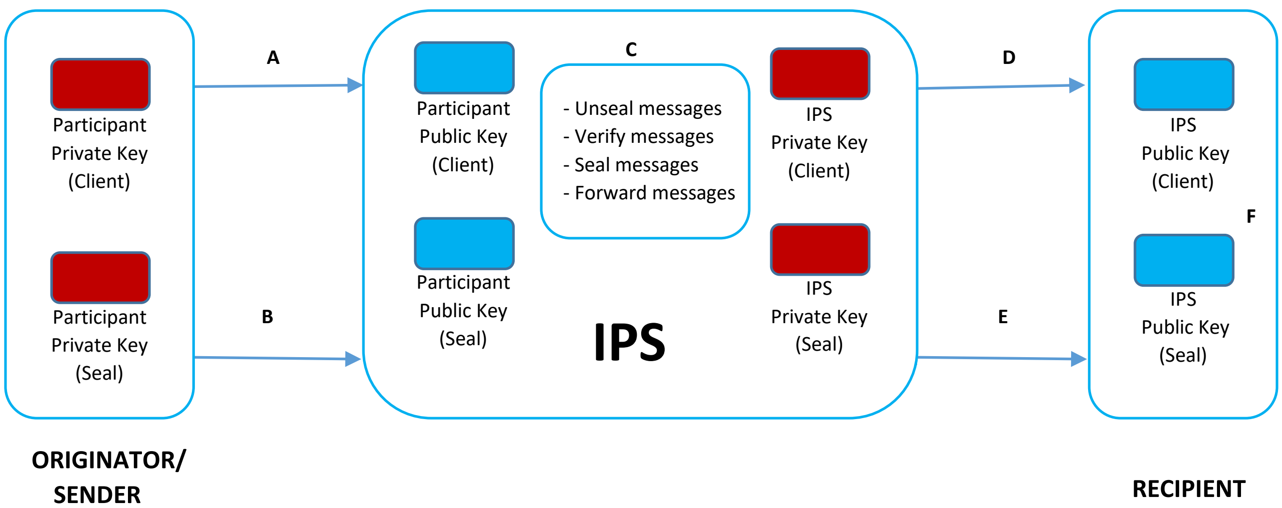
```
OpenSSL> req -text -in BANKXX_seal.csr   -noout -verify
problem creating object tsa_policy1=1.2.3.4.1
6940:error:08064066:object identifier routines:OBJ_create:oid exists:crypto\objects\obj_dat.c:698:
error in req
OpenSSL> exit

C:\Users\pmuiruri\Documents\Certificates and keys>openssl
OpenSSL> req -text -in BANKXX_seal.csr   -noout -verify
verify OK
Certificate Request:
    Data:
        Version: 1 (0x0)
        Subject: C = KE, ST = NAIROBI, L = NAIROBI, O = Internet Widgits Pty Ltd
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                RSA Public-Key: (2048 bit)
```

Once you have generated the CSR, send the CSR to IPSL for signing. We will sign the CSR, generate and send you back your x.509 certificate.

2. CERTIFICATE SHARING PROCEDURE

CERTIFICATES EXCHANGE DIAGRAM



A. Client initiates a secure client connection between the sender and IPS using the participant's client private key. IPS verifies that this connection belongs to the purported user by verifying the client request against their stored public key.
B. Once a secure connection has been established between the two parties, the sender will then digitally sign the message to be sent using their seal private key. The participant will then send the digitally signed message through this secure TLS connection.
C. IPS will receive the message and decrypt the digital signature using the participant's public key. If the public key can't decrypt the digital signature it means the signature isn't the participant's and the message will be rejected. If decryption succeeds, it will then calculate the hash of the original message, then compare the calculated hash with the decrypted hash from original message. Any difference would reveal tampering of the message and would thus be declined.
D. IPS initiates a secure client connection between the IPS and recipient using the IPS's client private key. Recipient verifies that this connection belongs to IPS user by verifying the client request against the *stored* IPS client public key.

E. Once a secure connection has been established between the two parties, IPS will then digitally sign the message to be sent using IPS seal private key. IPS will then send the digitally signed message through this secure TLS connection.
F. Recipient will receive the message and decrypt the digital signature using IPS's public key. If the public key can't decrypt the digital signature it means the signature isn't IPS's and the message will be rejected. If decryption succeeds, it will then calculate the hash of the original message, then compare the calculated hash with the decrypted hash from original message. Any difference would reveal tampering of the message and would thus be declined. If successful, the message is valid and processing continues.

This entire process can be summarized in the diagram below: